

Procedura di gestione degli incidenti di sicurezza e di funzionamento

1. Scopo

La presente procedura definisce le modalità di gestione degli incidenti di sicurezza e di funzionamento dei sistemi informativi di Acme Talent S.r.l., incluso il sistema TalentMatch. La procedura è stata testata con esercitazione tabletop il 15 gennaio 2025 e con una simulazione di incidente reale il 20 giugno 2025.

2. Ruoli e responsabilità

Incident Manager: responsabile IT, coordina la risposta. Team tecnico: due sviluppatori reperibili a rotazione. DPO: coinvolto se l'incidente riguarda dati personali. Direzione: informata per incidenti di livello Alto o Critico. Comunicazione esterna: ufficio legale.

3. Classificazione ed escalation

Gli incidenti sono classificati in quattro livelli: Basso, Medio, Alto, Critico. Criteri di escalation: un incidente passa ad Alto se coinvolge dati personali o interrompe il servizio per più di 2 ore; a Critico se coinvolge categorie particolari di dati o più di 1.000 interessati. Tempi di risposta: presa in carico entro 1 ora (Basso/Medio) o 30 minuti (Alto/Critico); comunicazione al Garante entro 72 ore ove richiesto.

4. Playbook di risposta

Fasi: 1) rilevazione e apertura ticket; 2) triage e classificazione; 3) contenimento (isolamento del componente, revoca credenziali); 4) eradicazione; 5) ripristino; 6) analisi post-incidente entro 10 giorni lavorativi con individuazione della root cause e delle azioni correttive.

5. Registro degli incidenti

Tutti gli incidenti sono registrati nel registro incidenti (strumento: Jira, progetto INC). Ogni voce riporta: timeline degli eventi, impatto, root cause, azioni correttive, verifica successiva dell'efficacia. Estratto del registro 2025: INC-2025-003 (14/02/2025, Medio): degrado delle prestazioni di TalentMatch per 90 minuti; root cause: esaurimento memoria del servizio di embedding; azione correttiva: limite di memoria e autoscaling; verifica: nessuna recidiva in 6 mesi. INC-2025-007 (03/05/2025, Alto): anomalia nei punteggi per candidature in lingua tedesca; root cause: aggiornamento del modello senza test di regressione multilingua; azione correttiva: suite di test multilingua obbligatoria prima del rilascio; verifica: audit del 10/06/2025.